

Molecule OnChainLab Audit Summary

Prepared by Cyfrin

Version 2.0

Lead Auditors

Kage

Al-qaqa

May 12, 2026

Contents

1 About Cyfrin 2

2 About This Document 2

3 Disclaimer 2

4 Copyright and License 2

5 Audit Overview 3

6 Audit Scope 4

7 Risk Classification 4

8 Protocol Summary 4

9 Attestation 4

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Molecule on OnChainLab. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

It is deliberately abbreviated: the technical detail of individual findings is not reproduced here. The complete audit report, version 2.0 dated May 12, 2026, was delivered to Molecule, who retain it as the full record of the engagement. This summary was issued on October 29, 2026.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Molecule or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 8 days, the Cyfrin team conducted an audit on the OnChainLab code provided by Molecule. The findings consist of 1 Critical, 2 High, 4 Medium & 11 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	OnChainLab
Repository	onchainlabs
Commit	4fb77ceee047...
Fix Commit	ca9817e69e50...
Audit Timeline	Apr 27th - May 6th, 2026
Methods	Manual Review

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	1	1	0
High Risk	2	2	0
Medium Risk	4	4	0
Low Risk	11	10	1
Informational	13	12	1
Gas Optimizations	5	5	0
Total	36	34	2

6 Audit Scope

The audit scope was limited to:

```
src/core/ERC6551Registry.sol
src/core/ExecutorManager.sol
src/core/OclDerivationConfig.sol
src/core/OnChainLabBeacon.sol
src/core/OnChainLabRouter.sol
src/core/SelectorManager.sol
src/core/ValidationManager.sol
src/ERC7484Registry/ERC7484Registry.sol
src/ERC7484Registry/ERC7484RegistryAdapter.sol
src/factory/OnChainLabFactory.sol
src/identity/MoleculeOclDidRegistry.sol
src/identity/OdfCoAttestVerifier.sol
src/modules/validator/RootValidator.sol
src/NFT/LabNFT.sol
src/utils/Create2Lib.sol
src/utils/ExecLib.sol
src/utils/OclIdLib.sol
src/utils/ModuleLib.sol
src/utils/ValidationTypeLib.sol
src/OnChainLab.sol
```

7 Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

8 Protocol Summary

OnChainLab is a modular smart-account system that binds an ERC-4337 account abstraction execution path and an ERC-7579 module installation surface to an ERC-721 ownership token (`LabNFT`) via the ERC-6551 token-bound-account standard. Each `LabNFT` mint creates a deterministic CREATE2 account whose signer is dynamically resolved as the current NFT owner.

A separate `MoleculeOclDidRegistry` binds OCL identities to external DIDs via EIP-712 signed `LinkDidRequest` payloads, with co-attestation performed by `OdfCoAttestVerifier` (asymmetric Kamu raw-ECDSA + Molecule EIP-712). All contracts deploy via Nick's CREATE2 deployer to byte-identical addresses across Sepolia, Base Sepolia, and Ethereum mainnet (canonical chain ID 8453 is baked into account derivation), so address-level identity is preserved cross-chain even though each deployment is single-chain at runtime.

9 Attestation

Cyfrin attests that it performed a security review of the OnChainLab code provided by Molecule.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2026-05-12-cyfrin-molecule-onchainlab-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Molecule has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=be759eb040e7bcc0cfa07292fe284f2b2c31cc0eb854bc03cd0f6b47294b82b1
F=2026-05-12-cyfrin-molecule-onchainlab-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.